

Analytical MCQ Assessment

High-level cognitive evaluation paper.

SECTION A: Multiple Choice Questions

Q1. In a hybrid encryption system, how is the symmetric session key securely shared between the sender and the receiver? (1 Marks)

- A. It is encrypted using the sender's private key.
- B. It is encrypted using the receiver's public key.
- C. It is sent via an out-of-band physical channel.
- D. It is hashed using a cryptographic hash function.

Q2. Which access control model is most appropriate for enforcing a non-discretionary, classification-based security policy where users must have a clearance level equal to or higher than the data's sensitivity? (1 Marks)

- A. Role-Based Access Control (RBAC)
- B. Discretionary Access Control (DAC)
- C. Mandatory Access Control (MAC)
- D. Attribute-Based Access Control (ABAC)

Q3. Which type of firewall is designed to track the state of active connections and make filtering decisions based on the context of the traffic flow rather than just individual packets? (1 Marks)

- A. Packet Filtering Firewall
- B. Stateful Inspection Firewall
- C. Application-Level Gateway
- D. Circuit-Level Gateway

Q4. An attacker inputs "' OR '1'='1" into a login form's username field to bypass authentication. What type of vulnerability did the attacker exploit, and what is the primary mitigation strategy? (1 Marks)

- A. Cross-Site Scripting (XSS); mitigate with output encoding.
- B. SQL Injection; mitigate with parameterized queries.
- C. Command Injection; mitigate with input length limits.
- D. Broken Authentication; mitigate with multi-factor authentication.

Q5. A company calculates the Single Loss Expectancy (SLE) of a server failure at \$10,000 and estimates the Annualized Rate of Occurrence (ARO) to be 0.5. What is the Annualized Loss Expectancy (ALE) for this risk scenario? (1 Marks)

- A. \$5,000
- B. \$10,000
- C. \$20,000
- D. \$2,500

Q6. Which open standard protocol is specifically designed for exchanging authentication and authorization data between an identity provider and a service provider in a federated identity solution? (1 Marks)

- A. Kerberos
- B. SAML 2.0
- C. LDAP
- D. RADIUS

Q7. An attacker positions themselves between a user's browser and a banking website, intercepting and altering the communication in real-time without either party's knowledge. What type of attack is being described? (1 Marks)

- A. Replay Attack
- B. Man-in-the-Middle (MitM) Attack
- C. Denial of Service (DoS) Attack
- D. Side-Channel Attack

Q8. Which cryptographic property must a key exchange protocol support to guarantee that even if an attacker compromises the long-term private key of a server, they cannot decrypt past TLS sessions? (1 Marks)

- A. Perfect Forward Secrecy (PFS)
- B. Non-repudiation
- C. Symmetric Key Escrow
- D. Homomorphic Encryption

Q9. During a forensic investigation of a compromised server, which of the following data sources should the investigator capture first to adhere to the order of volatility? (1 Marks)

- A. Hard drive image
- B. Routing table and ARP cache
- C. CPU registers and cache
- D. System backup tapes

Q10. An unauthorized individual gains access to a secure facility by closely following an authorized employee through an access-controlled door. What is this breach called, and what is a common physical control to prevent it? (1 Marks)

- A. Piggybacking; prevented by security guards.
- B. Tailgating; prevented by a mantrap.
- C. Shoulder surfing; prevented by privacy filters.
- D. Social engineering; prevented by security awareness training.

INSTRUCTOR ONLY - ANSWER KEY & RUBRIC

MCQ Solutions & Rationale

Q1. Correct Answer: B

Rationale: In hybrid encryption, the symmetric session key is encrypted with the recipient's public key to ensure confidentiality during transit.

Q2. Correct Answer: C

Rationale: Mandatory Access Control restricts access based on data sensitivity labels and user clearance levels.

Q3. Correct Answer: B

Rationale: Stateful inspection firewalls monitor the state of active connections to dynamically allow returning traffic.

Q4. Correct Answer: B

Rationale: The attack is a SQL injection, which is best mitigated by using parameterized queries or prepared statements.

Q5. Correct Answer: A

Rationale: ALE is calculated by multiplying the Single Loss Expectancy (SLE) by the Annualized Rate of Occurrence (ARO).

Q6. Correct Answer: B

Rationale: Security Assertion Markup Language (SAML) 2.0 is an XML-based standard for exchanging authentication and authorization data.

Q7. Correct Answer: B

Rationale: A Man-in-the-Middle attack involves an unauthorized entity intercepting and potentially altering communications between two parties.

Q8. Correct Answer: A

Rationale: Perfect Forward Secrecy ensures that the compromise of a long-term key does not compromise past session keys.

Q9. Correct Answer: C

Rationale: According to the order of volatility, CPU registers and cache are the most volatile and must be captured first.

Q10. Correct Answer: B

Rationale: Tailgating is the act of following an authorized person into a secure area, and it is effectively prevented by a mantrap.